📌 Credential Harvesting using Social-Engineer Toolkit (SET)

🎯 Objective

Simulate a **credential harvesting phishing attack** in a controlled lab environment using the *Social-Engineer Toolkit (SET)* by cloning a legitimate login page and capturing user-submitted credentials.

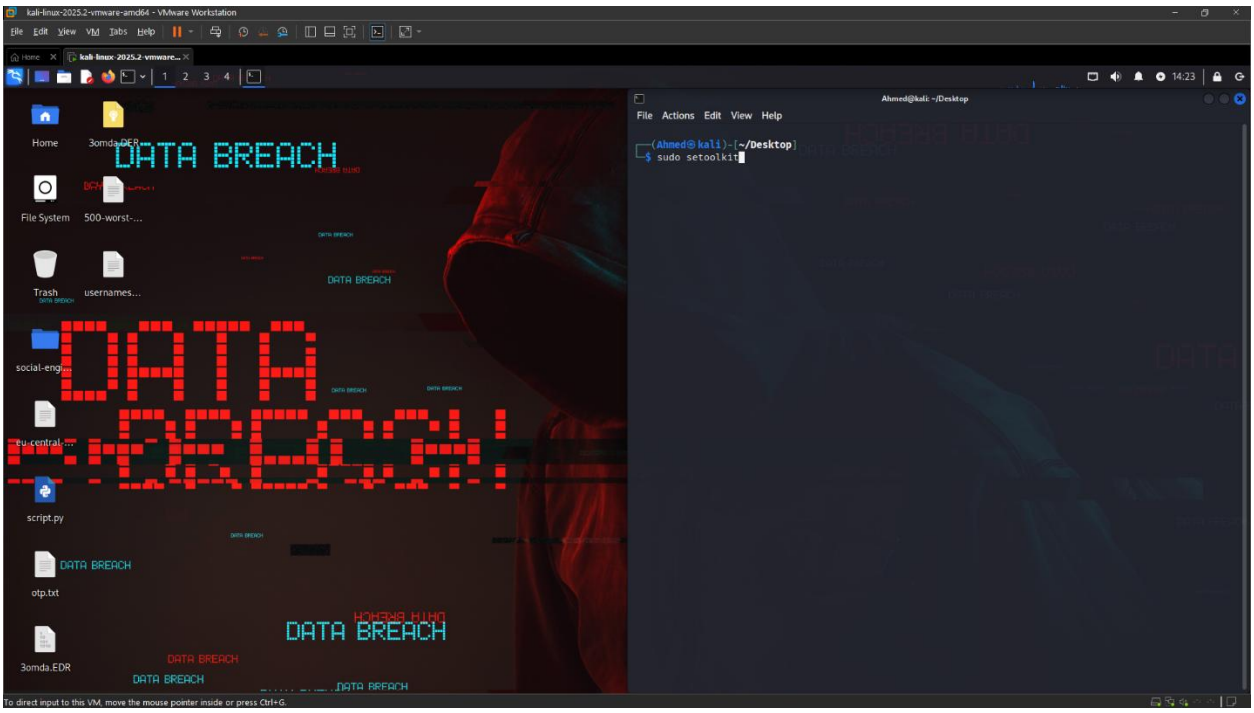
Author : Ahmed Emad Eldeen Abdelmoneam Mousa Nasr

🧪 Phase 1: Setup & Configuration

🔹 Initializing the Toolkit

The experiment was conducted on a **Kali Linux** machine.
The *Social-Engineer Toolkit (SET)* was launched with root privileges:

sudo setoolkit

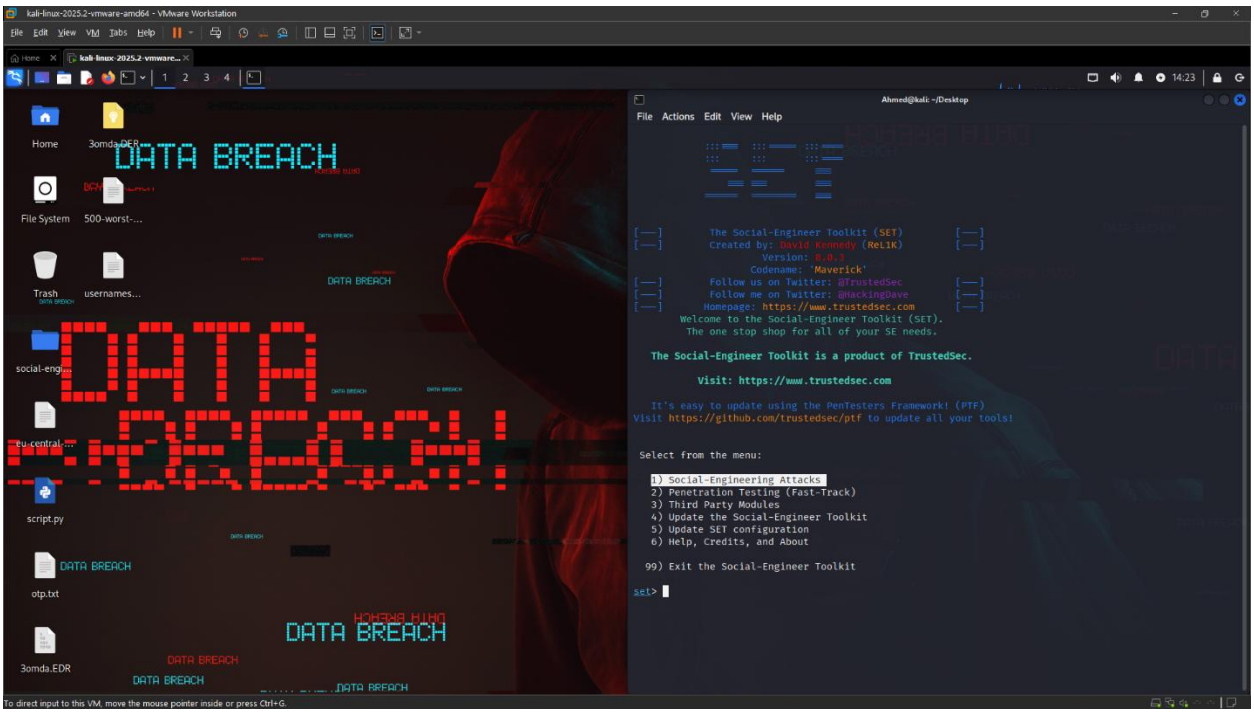


- **Selecting the Attack Vector**

From the SET main menu:

- (1) Social-Engineering Attacks
- (2) Website Attack Vectors

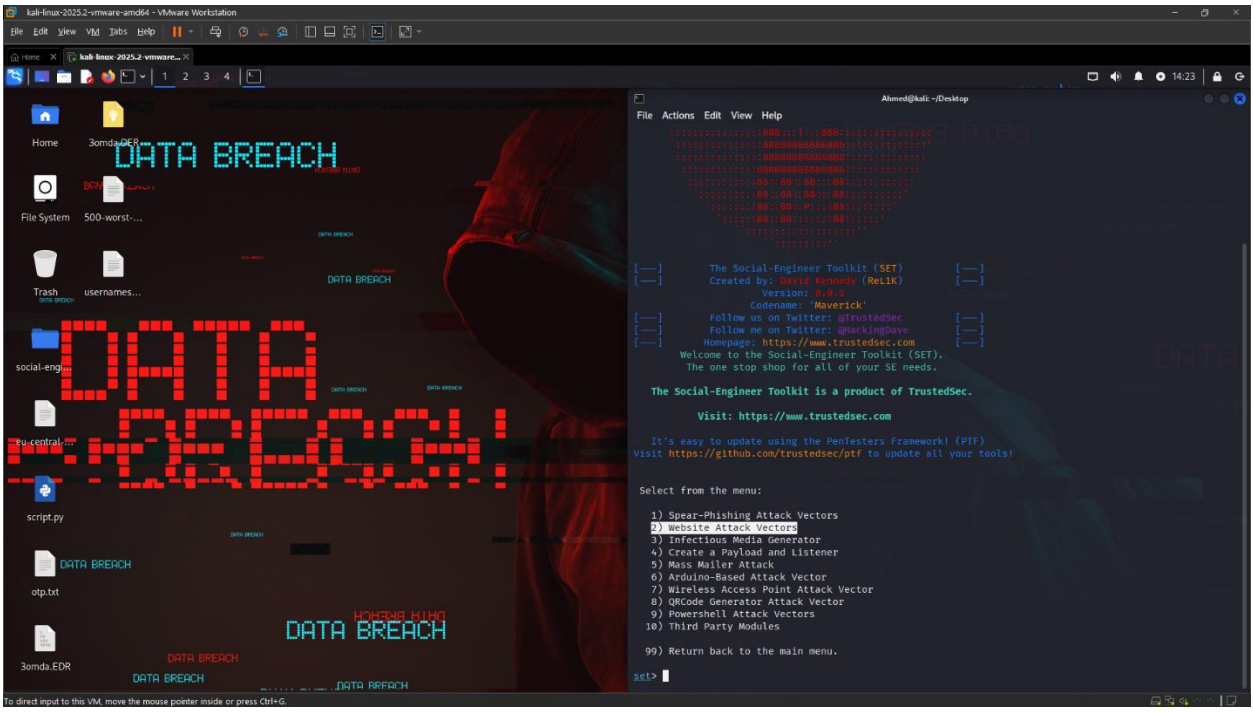
This path targets **browser-based social engineering attacks**.

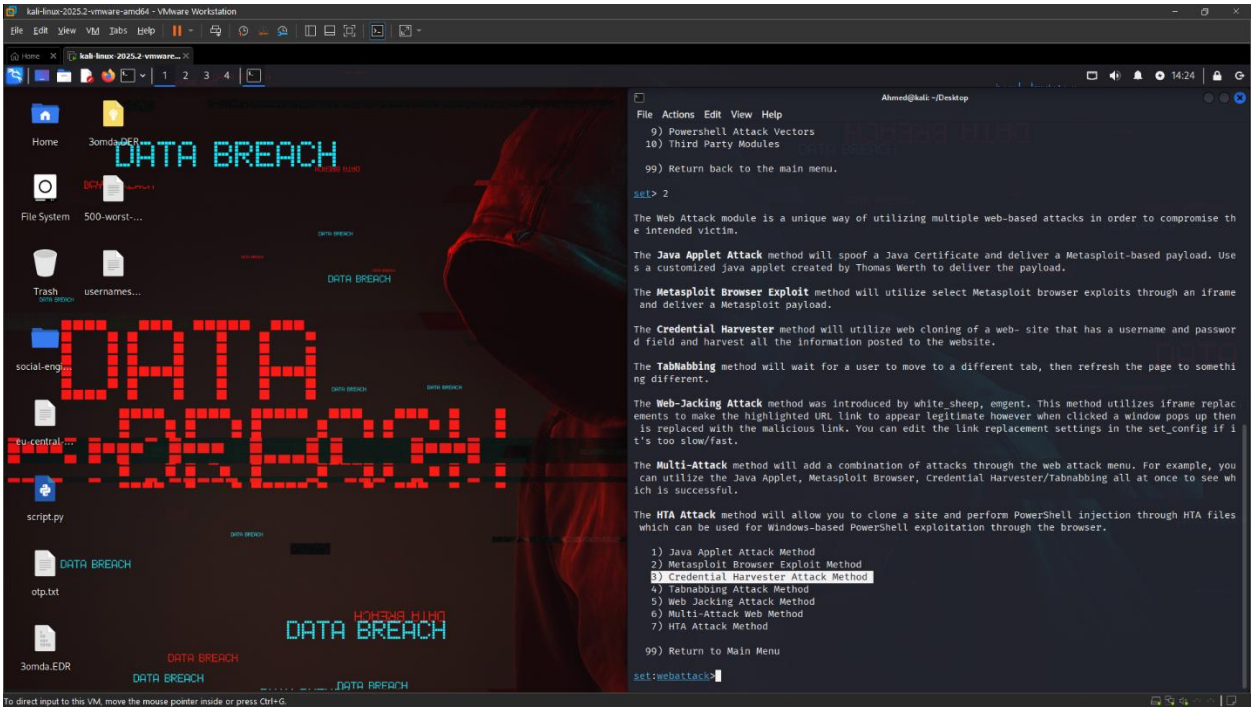


- **Defining the Attack Method**

- Selected: **(3) Credential Harvester Attack Method**
- Chosen option: **(1) Web Templates**

This method clones a legitimate login page and captures submitted credentials via HTTP POST requests.


kali-linux-2025.2-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
Ahmed@kali: ~/Desktop
File Actions Edit View Help
The Social-Engineer Toolkit (SET)
Created by: David Kennedy (ReL1K)
Version: 8.0.3
Codename: 'Maverick'
Follow us on Twitter: @TrustedSec
Follow me on Twitter: @HackingDave
Homepage: https://www.trustedsec.com
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.
The Social-Engineer Toolkit is a product of TrustedSec.
Visit: https://www.trustedsec.com
It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!
Select from the menu:
1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules
99) Return back to the main menu.
set>
DATA BREACH
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

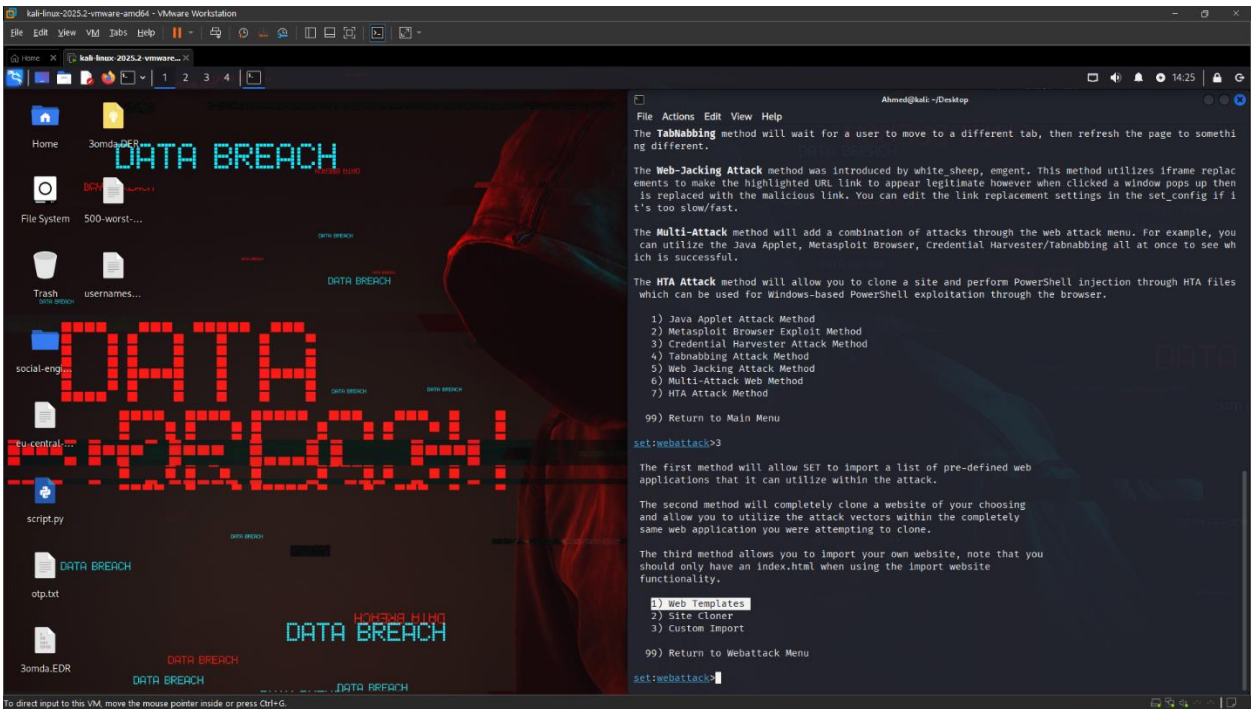

kali-linux-2025.2-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
Ahmed@kali: ~/Desktop
File Actions Edit View Help
9) Powershell Attack Vectors
10) Third Party Modules
99) Return back to the main menu.
set> 2
The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.
The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a customized java applet created by Thomas Werth to deliver the payload.
The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.
The Credential Harvester method will utilize web cloning of a web- site that has a username and password field and harvest all the information posted to the website.
The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.
The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.
The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.
The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windows-based PowerShell exploitation through the browser.
1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method
99) Return to Main Menu
set:webattack>
DATA BREACH
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

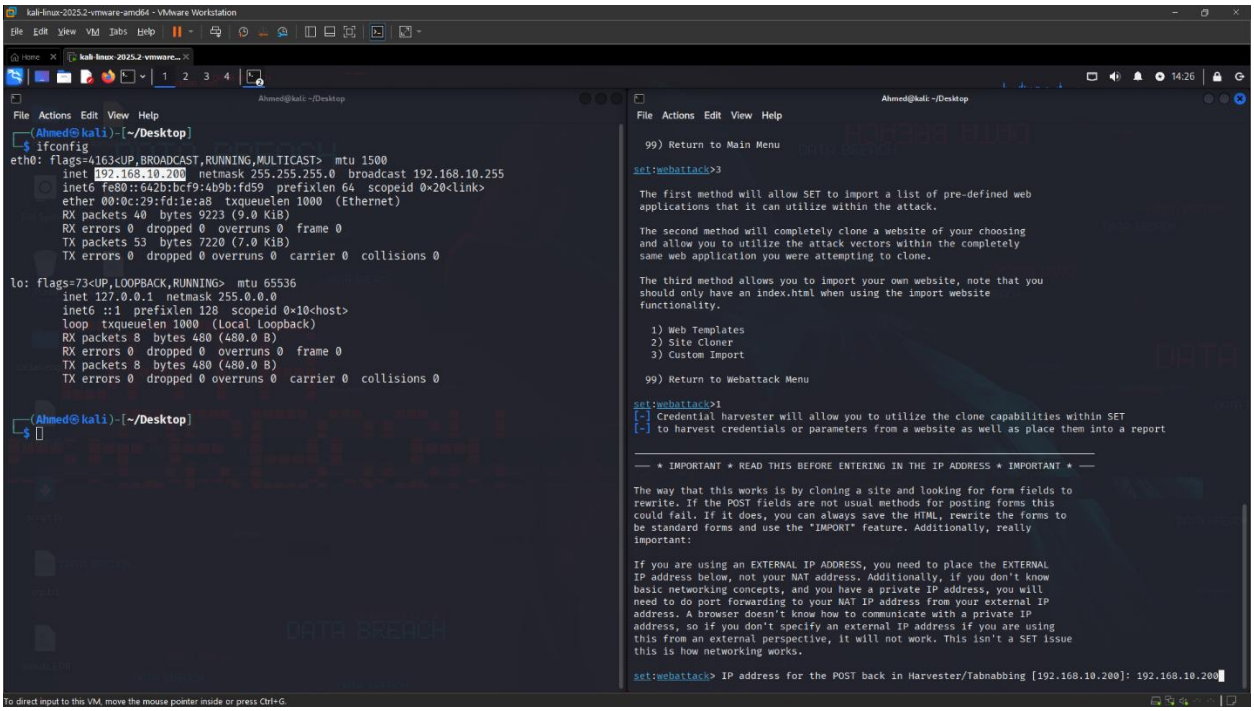
- **Configuring Listener & Network**

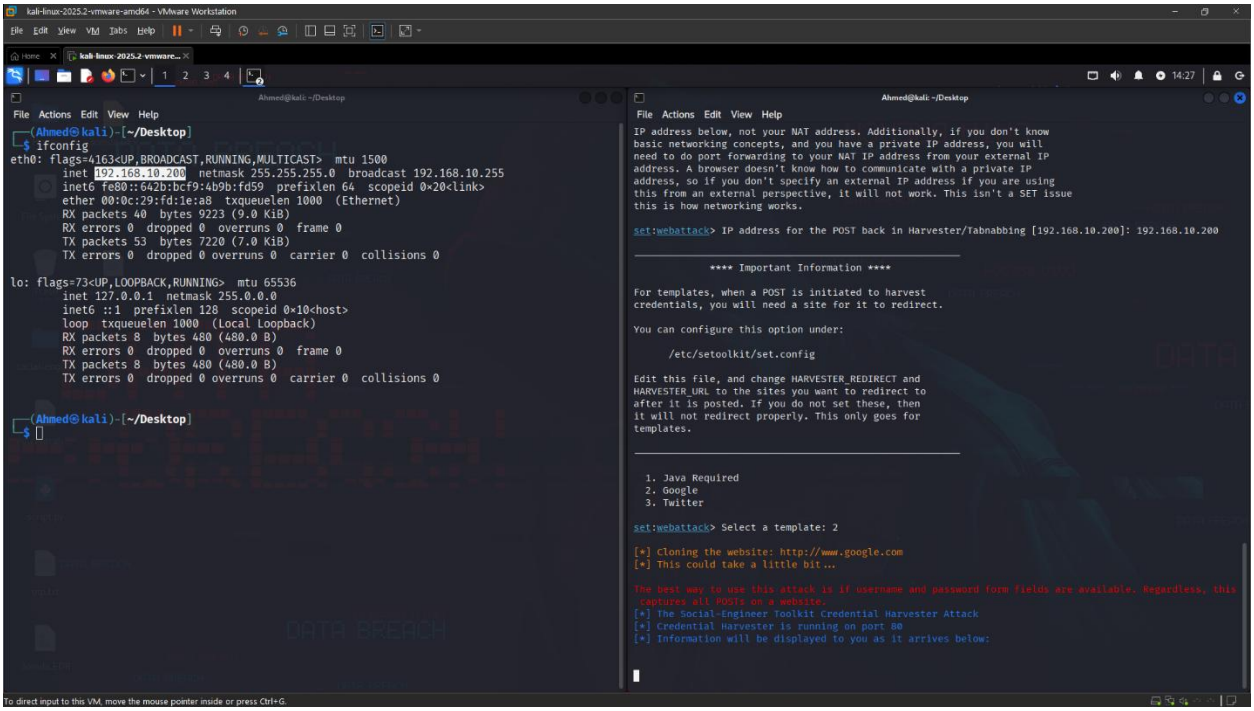
The attacker machine IP address was identified using:

ifconfig

- Attacker IP: **192.168.10.200**
- Configured as the **POST back IP** in SET
- Listener started on **Port 80**




kali-linux-2025.2-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
Home
kali-linux-2025.2-vmware...
14:26
Ahmed@kali: ~/Desktop
File Actions Edit View Help
(Ahmed㉿kali)-[~/Desktop]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
inet 192.168.10.200 netmask 255.255.255.0 broadcast 192.168.10.255
inet6 fe80::642b:bcf9:4b9b:fd59 prefixlen 64 scopeid 0x20<link>
ether 00:0c:29:fd:1e:a8 txqueuelen 1000 (Ethernet)
RX packets 40 bytes 9223 (9.0 KiB)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 53 bytes 7220 (7.0 KiB)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
inet 127.0.0.1 netmask 255.0.0.0
inet6 ::1 prefixlen 128 scopeid 0x10<host>
loop txqueuelen 1000 (Local Loopback)
RX packets 8 bytes 480 (480.0 B)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 8 bytes 480 (480.0 B)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
(Ahmed㉿kali)-[~/Desktop]
$
Ahmed@kali: ~/Desktop
File Actions Edit View Help
99) Return to Main Menu
set:webattack>3
The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.
The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.
The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.
1) Web Templates
2) Site Cloner
3) Custom Import
99) Return to Webattack Menu
set:webattack>1
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report
── * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * ──
The way that this works is by cloning a site and looking for form fields to rewrite. If the POST fields are not usual methods for posting forms this could fail. If it does, you can always save the HTML, rewrite the forms to be standard forms and use the "IMPORT" feature. Additionally, really important:
If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL IP address below, not your NAT address. Additionally, if you don't know basic networking concepts, and you have a private IP address, you will need to do port forwarding to your NAT IP address from your external IP address. A browser doesn't know how to communicate with a private IP address, so if you don't specify an external IP address if you are using this from an external perspective, it will not work. This isn't a SET issue this is how networking works.
set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.10.200]: 192.168.10.200
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.


kali-linux-2025.2-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
Home
kali-linux-2025.2-vmware...
14:27
Ahmed@kali: ~/Desktop
File Actions Edit View Help
(Ahmed㉿kali)-[~/Desktop]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
inet 192.168.10.200 netmask 255.255.255.0 broadcast 192.168.10.255
inet6 fe80::642b:bcf9:4b9b:fd59 prefixlen 64 scopeid 0x20<link>
ether 00:0c:29:fd:1e:a8 txqueuelen 1000 (Ethernet)
RX packets 40 bytes 9223 (9.0 KiB)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 53 bytes 7220 (7.0 KiB)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
inet 127.0.0.1 netmask 255.0.0.0
inet6 ::1 prefixlen 128 scopeid 0x10<host>
loop txqueuelen 1000 (Local Loopback)
RX packets 8 bytes 480 (480.0 B)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 8 bytes 480 (480.0 B)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
(Ahmed㉿kali)-[~/Desktop]
$
Ahmed@kali: ~/Desktop
File Actions Edit View Help
IP address below, not your NAT address. Additionally, if you don't know basic networking concepts, and you have a private IP address, you will need to do port forwarding to your NAT IP address from your external IP address. A browser doesn't know how to communicate with a private IP address, so if you don't specify an external IP address if you are using this from an external perspective, it will not work. This isn't a SET issue this is how networking works.
set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.10.200]: 192.168.10.200
**** Important Information ****
For templates, when a POST is initiated to harvest credentials, you will need a site for it to redirect.
You can configure this option under:
/etc/setoolkit/set.config
Edit this file, and change HARVESTER_REDIRECT and HARVESTER_URL to the sites you want to redirect to after it is posted. If you do not set these, then it will not redirect properly. This only goes for templates.
1. Java Required
2. Google
3. Twitter
set:webattack> Select a template: 2
[*] Cloning the website: http://www.google.com
[*] This could take a little bit...
The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

🔹 **Selecting the Template**

- Selected template: **Google Login Page**

SET automatically:

- Cloned the login interface
- Hosted it locally
- Started listening for incoming connections

⚡ **Phase 2: Execution & Credential Harvesting**

🔹 **Victim Interaction**

The victim accessed:

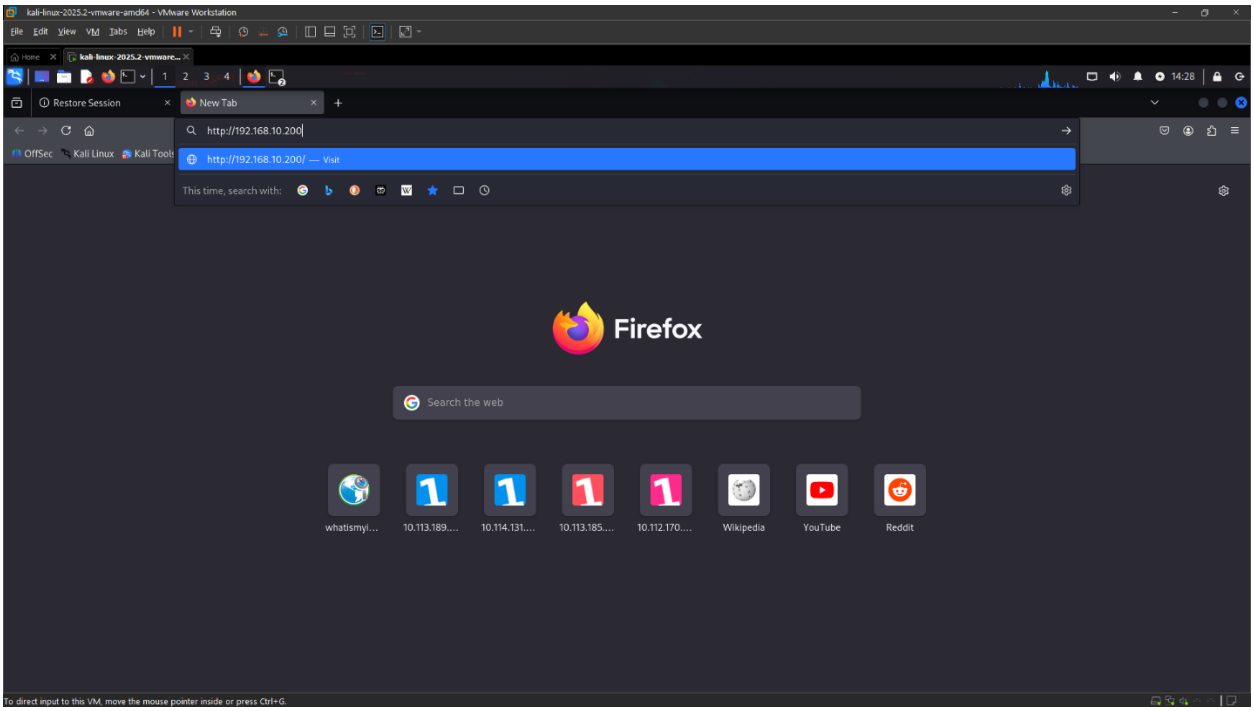
http://192.168.10.200/

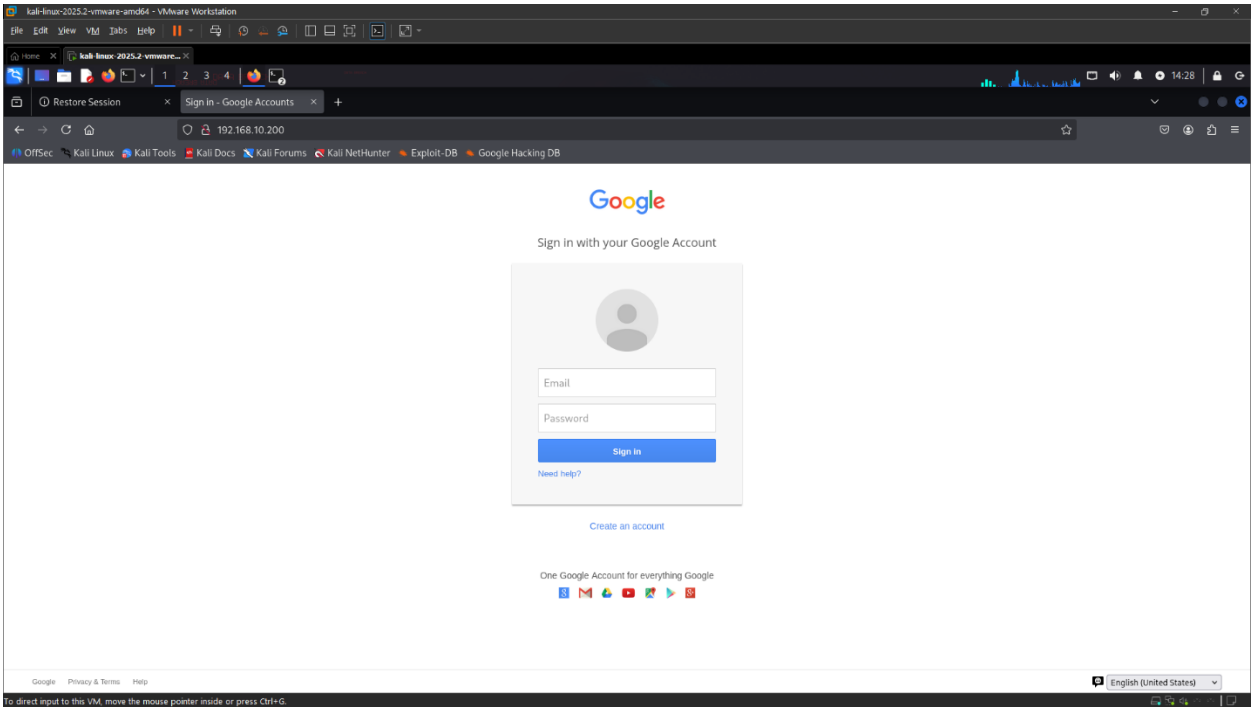
The page rendered a **visually identical clone** of the Google sign-in page.

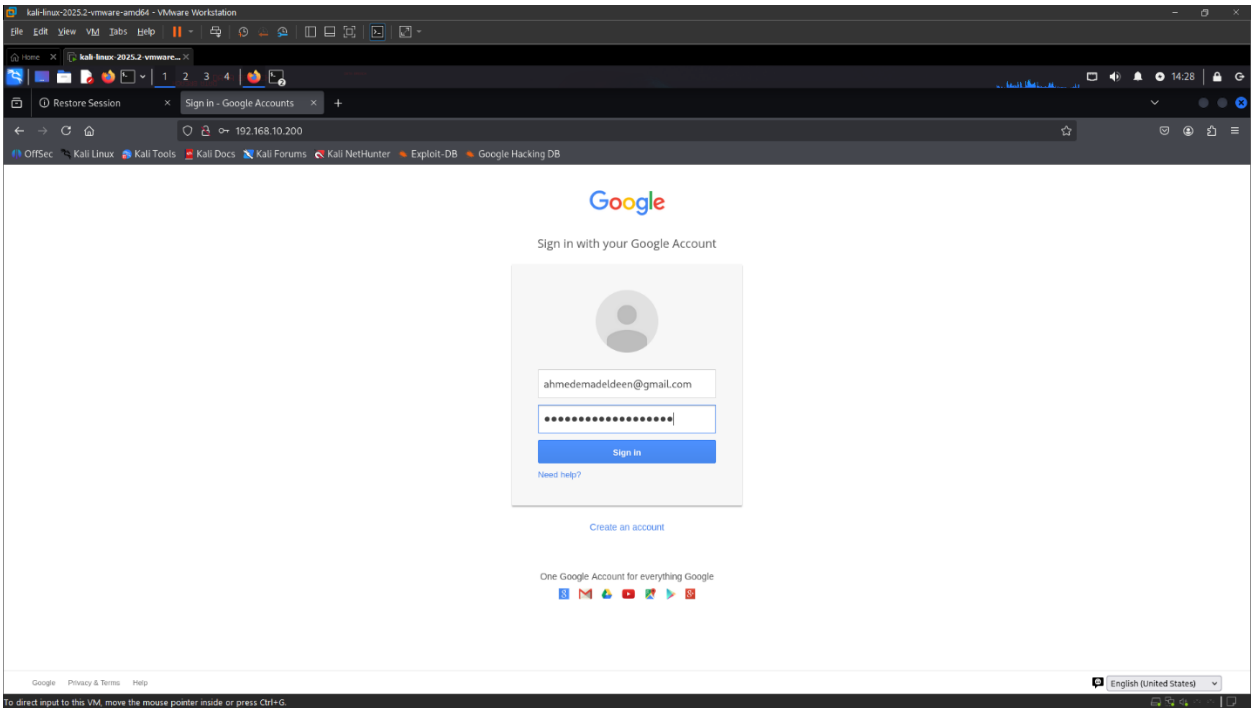
🔹 **Credential Submission**

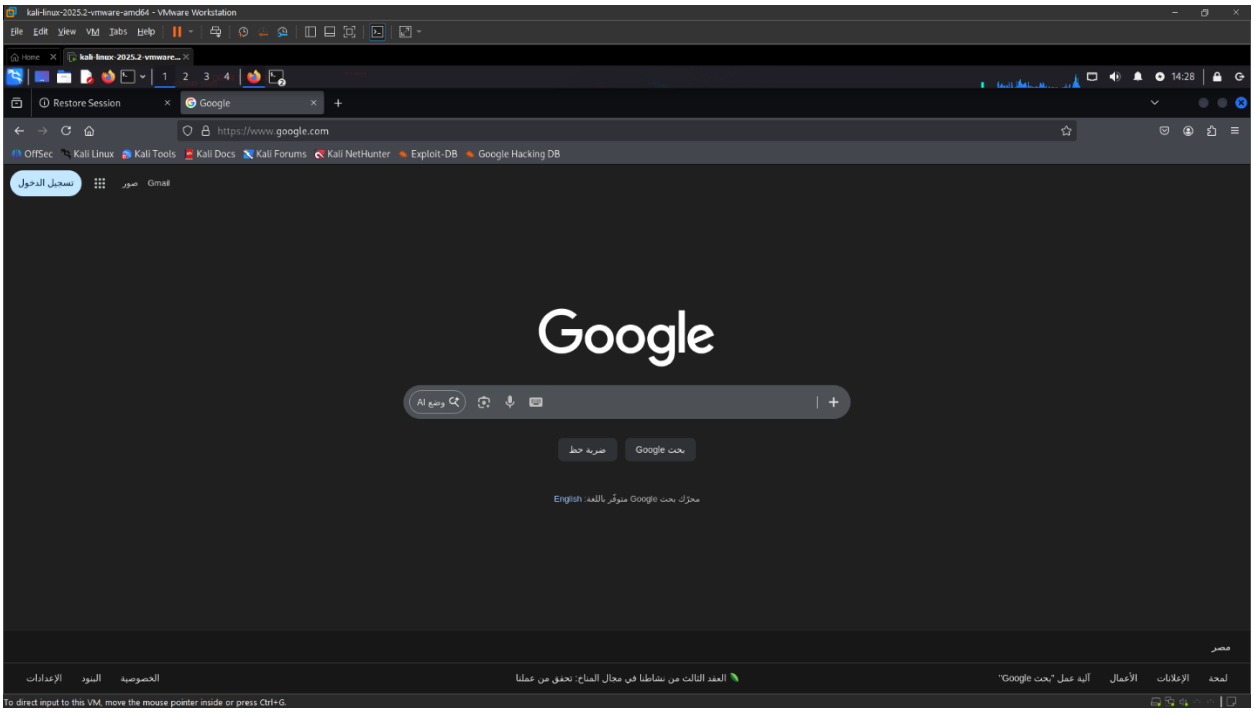
The victim entered:

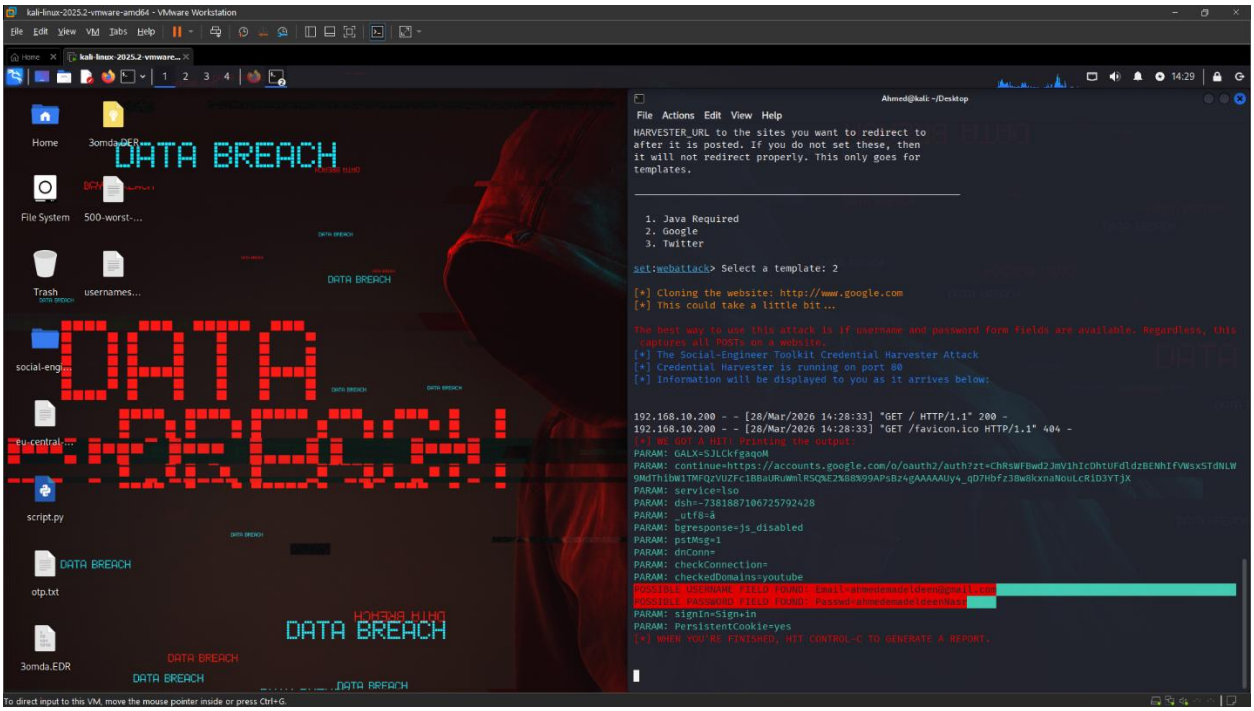
- Email: ahmedemadeldeen@gmail.com
- Password: [Redacted]


kali-linux-2025.2-vmware-amd64 - VMware Workstation
Restore Session
New Tab
http://192.168.10.200
http://192.168.10.200/ — Visit
This time, search with:
Firefox
Search the web
whatismyi...
10.113.189....
10.114.131....
10.113.185....
10.112.170....
Wikipedia
YouTube
Reddit
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.


kali-linux-2025.2-vmware-amd64 - VMware Workstation
Restore Session
Sign in - Google Accounts
192.168.10.200
Google
Sign in with your Google Account
Email
Password
Sign in
Need help?
Create an account
One Google Account for everything Google
Google
Privacy & Terms
Help
English (United States)
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.


kali-linux-2025.2-vmware-amd64 - VMware Workstation
Sign in - Google Accounts
192.168.10.200
Google
Sign in with your Google Account
ahmedemadeldeen@gmail.com
Sign in
Need help?
Create an account
One Google Account for everything Google
English (United States)
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.


kali-linux-2025.2-vmware-amd64 - VMware Workstation
Google
https://www.google.com
تسجيل الدخول
Gmail
صور
Google
بحث Google
ضربة حظ
English
مصر
الإعدادات
البنود
الخصوصية
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.



🔹 Redirection (Evasion Technique)

After submission, SET redirected the victim to:

https://www.google.com

📌 Purpose:

- Reduce suspicion
- Simulate a login error
- Encourage repeated credential entry

🔹 Credential Capture

On the attacker machine, SET captured and displayed the credentials:

POSSIBLE USERNAME FIELD FOUND: Email=ahmedemadeldeen@gmail.com
POSSIBLE PASSWORD FIELD FOUND: Passwd=[Redacted]

📌 Credentials were captured in **plain text** via intercepted HTTP POST request.

🛡️ Defensive Perspective & Mitigation (SOC / IR View)

🔹 1. URL Verification & Security Awareness

Users must verify:

- Correct domain (e.g., accounts.google.com)
- Presence of valid **TLS/SSL certificate**

📌 Phishing pages often use:

- Raw IP addresses
- Typosquatted domains

🔹 2. Multi-Factor Authentication (MFA)

Implement strong MFA such as:

- Authenticator apps
- Hardware keys (FIDO2)

📌 Even if credentials are stolen, access remains blocked.

🔹 3. Password Managers

Enterprise password managers:

- Auto-fill credentials only for **trusted domains**
- Prevent credential submission on fake pages

🔹 4. Secure Web Gateways (SWG) & DNS Filtering

These solutions can:

- Block malicious IPs
- Detect newly registered suspicious domains

- Prevent direct IP-based browsing

🔹 5. Endpoint Detection & Response (EDR)

EDR solutions help detect:

- Suspicious browser behavior
- Unusual outbound connections
- Phishing-related activity patterns

🧠 Key Takeaways

- Social engineering attacks exploit **human trust, not technical vulnerabilities**
- Credential harvesting via cloned pages is **simple yet highly effective**
- Defense requires a combination of:
  - User awareness
  - Strong authentication
  - Network & endpoint security controls

- Author : Ahmed Emad Eldeen Abdelmoneam Mousa Nasr
- **Job title / role:** Incident Response Analyst
- **Department / team:** Security Operations Center (SOC)
- **Email address:** Ahmed.em.nasr@gmail.com
- **Phone number:** +201018166445